

# Holistic Risk Management for Next-Gen Technologies Using AI and Governance Standards

Samuel Oakes<sup>1</sup>[0009-0003-2508-2161]

<sup>1</sup> Sacred Heart University, Fairfield CT 06825, USA  
[oakess2@mail.sacredheart.edu](mailto:oakess2@mail.sacredheart.edu)

## Abstract

Emerging technologies like AI, blockchain, and quantum computing drive innovation but introduce systemic risks that outpace traditional governance frameworks. While standards such as ISO/IEC 27001, NIST Cybersecurity Framework (CSF), and FAIR provide foundational controls, they lack mechanisms for real-time, adaptive risk assessment in dynamic environments. This paper bridges this gap by proposing an AI-driven risk management platform that synthesizes governance, risk, and compliance (GRC) principles with a 22-dimension weighted scoring rubric. Deployed as a Dockerized container, the model evaluates organizational risk across technical, strategic, and operational domains-from cloud security posture to talent readiness-and generates large language model (LLM)-tailored mitigation strategies. A case study of a cybersecurity startup demonstrates the platform's efficacy, yielding a normalized risk score of 70.71/100 and actionable recommendations aligned with NIST CSF and ISO 27001 controls. By automating risk quantification, benchmarking against industry standards, and prioritizing ethical integration, this approach enables organizations to adopt emerging technologies responsibly without stifling innovation. The results highlight how AI-augmented governance can harmonize security, compliance, and agility in an era of exponential technological change, synthesizing with current established frameworks to build upon and improve risk management to align with emerging technologies.

**Keywords:** Emerging Technology, Risk Management, Cybersecurity Governance, Artificial Intelligence, Blockchain, Quantum Computing

# 1 Introduction

The advancement of emerging technologies—particularly artificial intelligence (AI), blockchain, and quantum computing—has accelerated innovation across industries, offering solutions to major societal challenges and improving operational efficiency. However, these same technologies also introduce significant, under-governed risks that, if not effectively managed, can cause more harm than good. From deep learning systems functioning as opaque “black boxes” to decentralized blockchain architectures that compromise data provenance, the traditional boundaries of risk management are being strained beyond their original design.

Ensuring that the risks associated with the integration of innovative technologies are identified, measured, and mitigated is critical to unlocking their potential benefits while protecting essential sectors such as healthcare, energy, and finance. This paper seeks to analyze and close the gap in effectively managing these risks in an environment where technological capabilities are evolving faster than regulatory or governance frameworks can adapt.

## 2 Background and literature review

Emerging technologies such as artificial intelligence (AI), blockchain, robotic automation, and quantum computing offer significant opportunities for economic advancement and societal benefit. However, these technologies also create novel risks that challenge conventional governance models, as well as a lack of oversight in exchange for more innovation, requiring us to improve upon existing frameworks and ensuring proper implementation for adaptable, interdisciplinary, and resilient risk management systems.

### 2.1 Defining Emerging technology risks

Emerging technology risks are defined by their complexity, uncertainty, and potential for systemic impact. Unlike traditional IT risks, which are often technical and isolated, these new risks are multidimensional—encompassing privacy, ethics, legal compliance, infrastructure resilience, and societal trust. Aljarrah et al. categorize these risks into systemic, operational, and regulatory layers, emphasizing the growing need for transparent and explainable systems in AI and blockchain infrastructures [4].

AI technologies, in particular, present governance challenges due to their autonomous behavior, difficulty in interpretability, and susceptibility to adversarial manipulation. Similarly, blockchain systems introduce trustless architectures that can undermine traditional oversight mechanisms and complicate data provenance and compliance audits [2]. Big data environments exacerbate these issues by increasing exposure to data leakage, bias, and cyber intrusion, especially in sectors where sensitive personal or biometric data is involved [20 16].

Wearable devices, IoT endpoints, and robotic process automation (RPA) expand the attack surface for cyber threats. For example, in the context of wearable tech used in sports, real-time geolocation and biometric monitoring systems have been shown to lack encryption and risk management protocols, thereby exposing users to surveillance and data misuse [22]. These examples underscore the importance of embedding governance into design and policy at the earliest stages of technology adoption.

### 2.2 Existing frameworks and limitations

Several established frameworks guide organizations in managing cyber risk and information assurance. These include the NIST Risk Management Framework (RMF), ISO/IEC 27001 for Information Security Management Systems, COBIT 2019 for IT governance, and ISO 31000 for enterprise risk management [5]. However, these standards are frequently criticized for their lack of flexibility, difficulty in scaling across different industries, and minimal applicability to non-traditional architectures such as AI-driven platforms or decentralized blockchain networks.

NIST SP 800-37 Rev. 2 updates the RMF to include a “Prepare” step that addresses organizational context and business alignment. However, it remains primarily applicable to static system boundaries and lacks explicit mechanisms for evaluating real-time, adaptive risks introduced by machine learning or cloud-native systems [5]. ISO/IEC 27001 provides strong baseline controls for confidentiality, integrity, and availability, yet fails to address explainability, lifecycle monitoring, and the ethical use of AI or blockchain [6]. Similarly, COBIT 2019 emphasizes strategic alignment between IT and business objectives but offers limited operational guidance for managing predictive or behavioral risks unique to AI [7].

De Smet and Mayer’s systematic review reveals that integration between IT governance and security risk management is one of the weakest links in current practice. Risk is often treated as an afterthought rather than a proactive pillar in system design, and risk officers are excluded from critical decision-making roles [8]. Further analysis by Grob et al. supports this view, showing that most commercial IT risk tools lack simulation, coordination, and real-time alerting functions, rendering them ineffective for dynamic threat environments [9].

Recent approaches such as the AIRMan framework and the 4D-ISS lifecycle model aim to address these limitations. AIRMan integrates AI-specific governance using ISO 31000 principles and contextual risk treatment methods tailored to evolving regulatory frameworks like the EU AI Act [14]. Similarly, 4D-ISS introduces continuous reassessment and feedback across the Define, Design, Deploy, and Drive phases of information system development, offering a more agile alternative to legacy frameworks [10]. Despite these innovations, adoption remains uneven. Many organizations, particularly SMEs, still lack the internal capacity, tools, and strategic support to implement integrated, continuous, and context-aware risk governance.

### **3 Strategic Gaps and Framework Evolution**

#### **3.1 Governance Misalignment and Cultural Disconnects**

Effective risk management for emerging technologies is hindered by misalignment between cybersecurity strategies and enterprise risk management (ERM). Alzoubi et al. highlight how frameworks like 4D-ISS enable real-time feedback loops and lifecycle tracking to better align IT security with evolving strategic risks [13]. However, without executive sponsorship and cultural adaptation, integration fails. This is echoed by Takamura et al., who argue that GRC failures stem more from lack of organizational ownership and communication than from technological constraints [2].

Boards and C-suites often see cybersecurity as a compliance issue rather than a business enabler. Resiliency studies demonstrate that strategic foresight and the alignment of cybersecurity with ERM significantly improve risk posture, but uptake remains inconsistent across industries [12].

3.2 Big Data, IoT, and Automation: Security Risk Governance

The era of big data and automation has revolutionized how organizations manage operations and extract insights, but it has simultaneously created complex cybersecurity and governance challenges. Big data ecosystems strain conventional governance, necessitating hybrid approaches that blend ISO/IEC 27001 with national legislation to ensure compliance and resilience [2].

Automation solutions have enhanced detection capabilities, but as Jakimoski notes, most enterprises still rely on manually triggered risk alerts, delaying mitigation and increasing incident severity [3]. The inclusion of AI in governance processes—such as anomaly detection, threat modeling, and policy enforcement—provides improved outcomes but requires proper training and oversight. Kanban-based models, like those studied by Dorca et al., prove valuable in increasing visibility, communication, and task ownership in cybersecurity teams, thus shortening risk response cycles and bridging governance-execution gaps [11].

3.3 Sector-Specific Risk Trends and Case Applications

Healthcare and critical infrastructure sectors face unique risk landscapes. The wearable tech industry in sports, for example, is highly vulnerable to identity theft and data leaks due to lack of encryption and proper governance controls [22]. In robotic process automation (RPA), rapid deployment without secure configurations has led to regulatory breaches and operational failures, particularly in finance and telecom [9].

Similarly, energy and public sector use cases demonstrate that blockchain’s decentralized trust model can undermine centralized governance norms. Luo et al. propose blockchain-based governance to enhance traceability, but acknowledge risks involving immutable data, privacy, and lack of enforceability. AI-specific risk models like AIRMan and governance guidelines like the EU AI Act offer forward-looking frameworks. Yet, they require industry adaptation and clearer legal backing to operationalize principles like transparency, accountability, and bias reduction [20].

4 AI-Driven Risk Assessment Model

This section describes how our 22-dimension scoring rubric feeds into an end-to-end AI assessment platform, how we evaluate its outputs, and how the solution is containerized and demonstrated via a case study. This tool aims to provide tailored AI insight based on industry, technical expertise and business alignment of an enterprise to provide a risk assessment and help prepare to integrate any emerging technologies into a business while mitigating the risk landscape.

4.1 Scoring Rubric

Table: Scoring Rubric for Emerging-Tech Risk Assessment

| Risk Dimension | Weight | Max Score | Rationale for Weighting |
|----------------|--------|-----------|-------------------------|
|----------------|--------|-----------|-------------------------|

|                                         |      |    |                                                    |
|-----------------------------------------|------|----|----------------------------------------------------|
| Business Strategy Alignment             | 0.06 | 10 | Strategic alignment is foundational                |
| Market Position & Competitive Advantage | 0.05 | 10 | Market impact is important but not always critical |
| Financial Impact & Investment           | 0.05 | 10 | Financial readiness is key for adoption            |
| Regulatory Compliance                   | 0.05 | 10 | Compliance is a must in regulated industries       |
| Organizational Readiness                | 0.05 | 10 | Change management and skills are crucial           |
| Asset Visibility                        | 0.04 | 10 | Knowing assets is a baseline for security          |
| Data Sensitivity & Classification       | 0.05 | 10 | Data is often the main target of attacks           |
| Access Management                       | 0.05 | 10 | IAM is a common attack vector                      |
| Network Security Posture                | 0.04 | 10 | Network is a key defense layer                     |
| Cloud Security                          | 0.05 | 10 | Cloud is increasingly critical                     |
| Third-Party Risk                        | 0.05 | 10 | Supply chain attacks are rising                    |
| Incident Detection & Response           | 0.05 | 10 | Response capability limits impact                  |
| Security Awareness Training             | 0.04 | 10 | Human error is a major risk                        |
| Governance, Risk & Compliance (GRC)     | 0.05 | 10 | Governance underpins all controls                  |
| Secure Development (SDLC)               | 0.04 | 10 | Secure code is essential for tech organizations    |
| Business Continuity & Resilience        | 0.04 | 10 | Outages can be catastrophic                        |
| Security Monitoring & Logging           | 0.04 | 10 | Visibility is key for detection                    |
| Risk Quantification & Reporting         | 0.03 | 10 | Communicating risk is important for buy-in         |
| Application Security                    | 0.04 | 10 | Apps are a common breach vector                    |
| Emerging Technology Adoption            | 0.03 | 10 | New tech brings new risks                          |
| Innovation Culture                      | 0.04 | 10 | Innovation drives competitive advantage            |
| Talent Management                       | 0.05 | 10 | Skills gaps are a top risk for new technologies    |

Each dimension is scored  $s_i \in$  according to the detail and positivity of the user's response. The overall risk score is computed and normalized to a 0–100 scale: Overall Score =  $(\sum_i w_i \cdot s_i \div \sum_i w_i) \times 10$

#### 4.2 Performance Metrics and Evaluation

Because the rubric is rule-based (not statistical), we assess effectiveness through:

- Manual review of rubric outputs across diverse synthetic and real company profiles
- Expert validation of LLM-generated recommendations for relevance and actionability
- Comparative alignment with industry frameworks such as NIST CSF, ISO/IEC 27001, and FAIR

#### 4.3 System Architecture and Deployment

The AI assessment pipeline comprises:

1. Ingest company profile via a REST API
2. Run the 22-dimension rubric evaluator (api.py) to obtain a score vector
3. Feed the vector and metadata into an LLM to generate tailored mitigation recommendations
4. Aggregate numeric scores and narrative advice into a unified risk report

Deployment is containerized in Docker for portability and security:

- Base image: python:3.11-slim
- Dependencies pinned in requirements.txt
- Dockerfile exposes port 5000 and launches api.py
- Security hardening: least-privilege user, resource limits, CI/CD vulnerability scans, and restricted network policies

#### 4.4 Case Study: Sample Company Profile and Output

Profile for a cybersecurity startup with minimal controls and early AI+cloud adoption:

- Industry: Cybersecurity
- Size: Startup
- Tech Adoption: Early Adopter
- Security Controls: Minimal, ad hoc
- Risk Posture: Brief, evolving
- Emerging Technologies: AI, Cloud

Sample Output:

- Overall Weighted Score: 70.71 / 100
- Top Risks (Score / Max):
  - Asset Visibility (4 / 10)
  - Incident Detection & Response (3 / 10)
  - Organizational Readiness (5 / 10)
- Recommendations:
  - Implement a formal risk assessment process for emerging technology adoption.
  - Develop a comprehensive security framework aligned with industry standards.
- Resources:
  - NIST Cybersecurity Framework ([nist.gov/cyberframework](https://nist.gov/cyberframework))
  - ISO/IEC 27001 Information Security Management ([iso.org/isoiec-27001-information-security.html](https://iso.org/isoiec-27001-information-security.html))

This case study demonstrates how our holistic AI platform leverages the weighted rubric to deliver both a quantitative risk score and actionable guidance.

## **5 Toward Effective Risk Management: Principles and Recommendations**

### **5.1 Integrative Governance by Design**

As reinforced by IRGC's framework, governance must be adaptive and participatory to manage ambiguous, uncertain risks. Risk must be governed not only through standards but through multi-stakeholder decision-making and pre-assessment mechanisms [17]. Unified GRC models, as discussed by Aljarrah et al. and Jakimoski, emphasize integrating AI governance, cybersecurity, and operational strategy via feedback loops and cross-functional decision trees [5 6].

### **5.2 Continuous Learning and Strategic Foresight**

Risk management should be embedded as a continuous process. Strategic foresight practices that align cybersecurity and ERM ensure early identification of high-impact risks. Training risk professionals to use predictive analytics, incident forensics, and AI validation models is vital [3].

### **5.3 Measured Onboarding and Gradual Integration**

Emerging technologies should not be rushed into production. As this paper argues, "we don't need to reinvent the wheel." Instead, applying proven controls while gradually onboarding new systems with sandbox testing and phase-based authorization minimizes risk. Systems should not access mission-critical data until compliance, security, and reliability are independently verified [12].

## **6 Case Studies**

### **6.1 Healthcare and Wearable Technologies**

The healthcare sector has experienced a surge in wearable technologies used for real-time health monitoring, but this innovation comes with substantial risk. Wearable devices used in sports and clinical monitoring often lack robust encryption and governance structures. A study on wearable technology in sports revealed that the absence of security protocols such as anonymization and access control exposes users to identity theft, unauthorized surveillance, and misuse of sensitive biometric data [22].

### **6.2 Robotic Process Automation in Finance**

Robotic Process Automation (RPA) has been adopted extensively in financial services for process optimization. However, rapid implementation without proper oversight has led to regulatory breaches, audit failures, and the exploitation of process vulnerabilities. One case demonstrated how poorly configured bots bypassed critical compliance checks, leading to unreported financial discrepancies. Risk governance in this space must evolve to monitor RPA behavior in real time and to integrate audit trails directly into workflows [9].

### **6.3 Blockchain in Energy and Public Sector**

Blockchain's immutable and decentralized design offers strong data traceability, but its deployment in government and energy sectors has revealed a lack of enforceability for smart contracts and data immutability concerns. For instance, energy projects using blockchain for asset tracking struggled to comply with privacy laws, as the technology could not accommodate regulatory requirements for data deletion or modification [19].

## **6.4 AI in Critical Infrastructure**

The application of AI in public safety, utility control, and defense operations raises ethical and operational challenges. The AIRMan framework was designed to address these issues through stakeholder-driven risk governance and adaptive monitoring [14]. However, many institutions lack the technical maturity or legal structure to enforce AI accountability, leading to inconsistent implementation and increased systemic exposure.

# **7 Recommendations**

## **7.1 Design Governance into the Technology Lifecycle**

Risk governance should be embedded at every stage of the technology lifecycle—from system design and development to deployment and decommissioning. Adopting lifecycle-based models such as 4D-ISS or AIRMan can enable real-time decision-making and dynamic risk reassessment [13].

## **7.2 Incentivize Cross-Functional Integration**

Risk should not be siloed in IT or compliance departments. Organizations must foster cross-functional alignment through executive sponsorship, stakeholder training, and cultural adaptation. Frameworks like MAVEN demonstrate that enterprise-wide engagement improves GRC outcomes and speeds up response times [18].

## **7.3 Adopt Sector-Specific Risk Postures**

Each industry faces unique regulatory, ethical, and operational threats. Risk frameworks should be tailored to sectoral needs, with specialized protocols for sectors like healthcare (e.g., HIPAA compliance), finance (e.g., SOX, GLBA), and energy (e.g., NERC CIP).

## **7.4 Enable Regulatory Sandboxes and Pilot Testing**

Organizations should adopt sandboxing approaches to test emerging technologies in controlled environments. These pilots can identify unforeseen risks, allow for stakeholder feedback, and create a feedback loop for continuous governance improvement.

## **7.5 Invest in Automation and AI-Augmented Oversight**

Human oversight remains critical, but automated tools are essential to scale governance in dynamic environments. Workflow automation, predictive analytics, and anomaly detection systems must be integrated into GRC platforms to maintain real-time visibility and compliance [3].

## 8 Conclusion

Emerging technologies promise transformative benefits but also introduce substantial, multifaceted risks that challenge existing governance and risk management models. This paper has reviewed existing literature and identified significant strategic, technical, and cultural gaps in contemporary approaches. Effective governance in this rapidly evolving technological landscape requires adaptive frameworks that integrate seamlessly with organizational strategy, incorporate continuous learning, and promote strategic foresight. Additionally, governance structures must be tailored to specific industry contexts, addressing unique sectoral challenges proactively. Organizations can achieve an optimal balance between innovation and resilience by embedding robust cybersecurity and comprehensive risk management practices deeply into their operational frameworks and organizational culture. Leveraging advanced AI-driven assessment tools and adopting measured onboarding strategies ensure that emerging technologies can be responsibly deployed, maximizing their potential benefits while effectively mitigating associated risks. Ultimately, a proactive, integrated, and human-centric approach will position organizations not only to manage current and future challenges but also to capitalize sustainably on technological advancements.

## References

1. Wang, X., Bai, X., Luo, W., Wang, Y.: Research on Big Data Security and Privacy Risk Governance. In: 2021 Int'l Conf. on Big Data, AI and Risk Management (ICBAR), pp. 1–7. IEEE (2021).
2. Jakimoski, K.: Automation Improvement in Cyber Risk Management. In: 2023 Int'l Conf. on Info Systems and Cyber Resilience, pp. 37–44. IEEE (2023).
3. Aljarrah, S., et al.: On the Comparative Analysis of Trends in Cybersecurity Risk Assessment, Governance, and Compliance Frameworks. In: 2024 Int'l Jordanian Cybersecurity Conf. (IJCC), pp. 1–11. IEEE (2024).
4. National Institute of Standards and Technology (NIST): Risk Management Framework for Information Systems and Organizations. NIST SP 800-37 Rev. 2 (2018).
5. International Organization for Standardization: ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection — ISMS (2022).
6. ISACA: COBIT 2019 Framework: Governance and Management Objectives. ISACA, Rolling Meadows, IL (2019).
7. De Smet, D., Mayer, N.: Integration of IT Governance and Security Risk Management: A Systematic Literature Review. In: i-Society 2016, pp. 1–7. IEEE (2016).
8. Boodai, R., Alessa, H., Alanazi, A.: An Approach to Address Risk Management Challenges Focused on IT Governance. In: 2022 IEEE Conf. on Cybersecurity and Resilience, pp. 180–188. IEEE (2022).
9. Grob, H.L., Strauch, G., Buddendick, C.: Applications for IT-Risk Management: Requirements and Practical Evaluation. In: ARES 2008, pp. 758–765. IEEE (2008).
10. Dorca, V., et al.: Agile Approach with Kanban in Information Security Risk Management. In: 2016 Int'l Conf. on Electrical and Electronics Engineering (ISEEE), pp. 1–6. IEEE (2016).
11. Yuan, W., Wang, H., Zhang, J., Qi, W.: Research on Risk Control System ITG-HRCM in IT Governance. In: ITME 2012, pp. 1005–1010. IEEE (2012).
12. Alzoubi, Y., et al.: A New Approach of Information System Security Governance: The 4D-ISS Model. In: 2023 Int'l Conf. on Cybersecurity Trends (CYTR), pp. 51–59. IEEE (2023).
13. Jakimoski, K.: AIRMan: An Artificial Intelligence Risk Management System. In: 2022 Int'l Conf. on Info Tech Security and Automation, pp. 22–30. IEEE (2022).
14. Dorca, V., et al.: Agile Kanban Integration for Risk Management Teams. In: ISEEE 2016, pp. 20–26. IEEE (2016).
15. IEEE Standards Association: IEEE Std 2145-2023 – Standard for Blockchain Governance and DLT Systems. IEEE, Piscataway, NJ (2023).
16. International Risk Governance Center (IRGC): Guidelines for Emerging Risk Governance. EPFL, Lausanne (2017).

17. Takamura, E., et al.: MAVEN Information Security Governance, Risk Management, and Compliance: Lessons Learned. In: IEEE Aerospace Conf. 2014, pp. 1–10. IEEE (2014).
18. Luo, W., Bai, X., Wang, X.: Improve Governance System Level and Apply Blockchain for Strategic Transformation. In: 2022 Int'l Conf. on Blockchain & Data Sharing, pp. 12–20. IEEE (2022).
19. European Commission: Proposal for a Regulation Laying Down Harmonised Rules on Artificial Intelligence (AI Act), COM/2021/206 Final. Brussels (2021).
20. ISO/IEC: ISO/IEC 42001:2023 Artificial Intelligence Management System Standard. ISO, Geneva (2023).
21. Laveti, S.: Risk Management: Understanding Security Risks in Emerging Technologies. Medium.  
<https://medium.com/@laveti/risk-management-understanding-security-risks-in-emerging-technologies-0fb43b88762e>,  
last accessed 2025/05/08.
22. IDC Research: Worldwide Security Spending Guide, 2023 Forecast. IDC. <https://www.idc.com>, last accessed 2025/05/08.